

IT PROFESSIONAL PORTFOLIO

Cloud Engineering and Security Projects

PROJECT 11

Secure the Centralized Logging S3 Bucket with a CloudTrail Bucket Policy

Amazon S3 | CloudTrail | Bucket Policies | Centralized Logging

AUTHOR	Michael Salazar
ENVIRONMENT	Personal AWS Lab
VERSION	v1.0.0
RELEASE DATE	July 10, 2026
STATUS	Complete

Executive Summary

Assumed the **SecurityAudit** account and applied a resource-based Amazon S3 bucket policy to the centralized logging bucket. The policy grants the **CloudTrail service** restricted access to validate the bucket ACL and write logs to controlled **AWSLogs** paths, while preserving S3 Block Public Access on the bucket.

Business Problem

Centralized CloudTrail logging requires the CloudTrail service to write logs into a bucket that lives in a separate security account. Without a carefully scoped bucket policy, the bucket might either reject legitimate CloudTrail delivery or expose a risky write path that other parties could abuse. A resource-based bucket policy allows controlled service-to-resource access without making the bucket public.

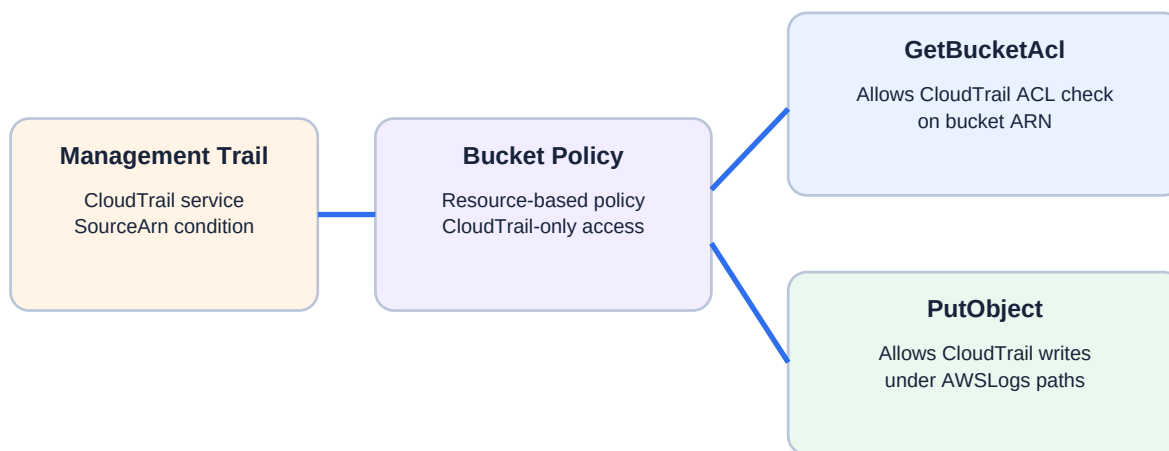
Objectives

- Assume the SecurityAudit account context before modifying the centralized logging bucket.
- Create and apply a resource-based S3 bucket policy for CloudTrail delivery.
- Allow CloudTrail to perform s3:GetBucketAcl against the logging bucket.
- Allow CloudTrail to perform s3:PutObject into controlled AWSLogs paths.
- Use aws:SourceArn conditions to bind access to the intended CloudTrail trail.
- Require bucket-owner-full-control for delivered log objects.
- Keep S3 Block Public Access enabled on the centralized logging bucket.

Environment

Active Account Context	SecurityAudit member account
Storage Service	Amazon S3
Logging Service	AWS CloudTrail
Policy Type	S3 bucket policy / resource-based policy
Bucket	
Public Access Setting	Block all public access enabled
Allowed Principal	cloudtrail.amazonaws.com
Allowed Actions	s3:GetBucketAcl and s3:PutObject
Key Conditions	aws:SourceArn and s3:x-amz-acl = bucket-owner-full-control
Purpose	Secure centralized CloudTrail log delivery path

Architecture



The bucket policy allows only the CloudTrail service to validate and write logs to controlled paths.
SourceArn and ACL conditions reduce confused-deputy and ownership risks.

Figure 1 - CloudTrail bucket policy for centralized logging access.

Implementation Summary

1. Started from the existing multi-account environment and assumed into SecurityAudit.
2. Opened the centralized logging S3 bucket created in the previous project.
3. Collected the required identifiers: management account ID, CloudTrail trail ARN, bucket ARN, and organization ID.
4. Customized the CloudTrail bucket policy template with the correct bucket and trail identifiers.
5. Allowed the CloudTrail service principal to call s3:GetBucketAcl on the bucket.
6. Allowed the CloudTrail service principal to call s3:PutObject into AWSLogs paths for the management account and organization.
7. Added conditions requiring the intended CloudTrail SourceArn and bucket-owner-full-control ACL.
8. Saved the policy and validated that the bucket policy was successfully edited while Block Public Access remained enabled.

TERMINOLOGY

This is documented as an **S3 resource-based bucket policy**. The evidence shows an S3 bucket policy, not an AWS Organizations Resource Control Policy. The user's shorthand **RCP** is treated here as the resource policy created for the bucket.

Policy Logic

AWSCloudTrailAclCheck20150319	Allows cloudtrail.amazonaws.com to call s3:GetBucketAcl on the bucket when the request comes from the intended trail ARN.
AWSCloudTrailWrite20150319	Allows CloudTrail to write objects under AWSLogs/* with bucket-owner-full-control.
AWSCloudTrailOrganizationWrite20150319	Allows CloudTrail to write organization log objects under AWSLogs/* with bucket-owner-full-control.
aws:SourceArn	Restricts access to the intended CloudTrail trail and helps reduce confused-deputy risk.
s3:x-amz-acl	Requires delivered objects to grant bucket-owner-full-control.

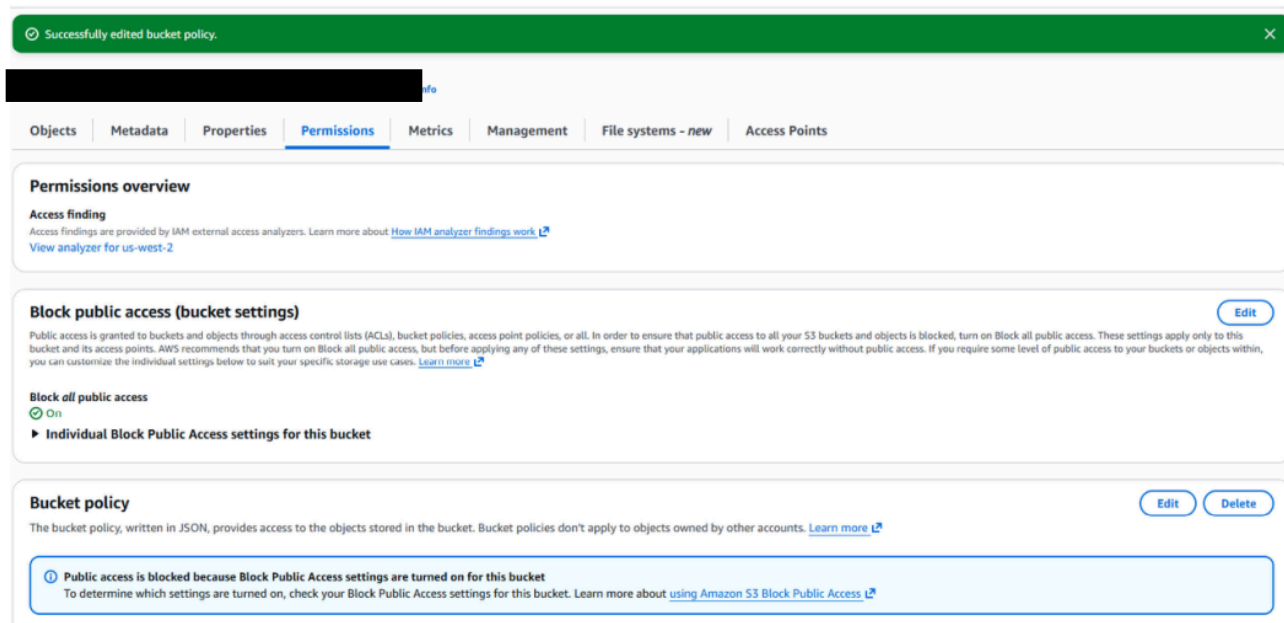
Evidence

Figure 2 - CloudTrail Resource Policy Template

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "AWSCloudTrailAclCheck20150319",
      "Effect": "Allow",
      "Principal": {
        "Service": [
          "cloudtrail.amazonaws.com"
        ]
      },
      "Action": "s3:GetBucketAcl",
      "Resource": "arn:aws:s3::bucket-arn",
      "Condition": {
        "StringEquals": {
          "aws:SourceArn": "arn:aws:cloudtrail:us-east-1:123456789012:trail/arn"
        }
      }
    },
    {
      "Sid": "AWSCloudTrailWrite20150319",
      "Effect": "Allow",
      "Principal": {
        "Service": [
          "cloudtrail.amazonaws.com"
        ]
      },
      "Action": "s3:PutObject",
      "Resource": "arn:aws:s3:::bucket-arn/AWSLogs/*",
      "Condition": {
        "StringEquals": {
          "s3:x-amz-acl": "bucket-owner-full-control",
          "aws:SourceArn": "arn:aws:cloudtrail:us-east-1:123456789012:trail/arn"
        }
      }
    },
    {
      "Sid": "AWSCloudTrailOrganizationWrite20150319",
      "Effect": "Allow",
      "Principal": {
        "Service": [
          "cloudtrail.amazonaws.com"
        ]
      },
      "Action": "s3:PutObject",
      "Resource": "arn:aws:s3:::bucket-arn/AWSLogs/organizationID/*",
      "Condition": {
        "StringEquals": {
          "s3:x-amz-acl": "bucket-owner-full-control",
          "aws:SourceArn": "arn:aws:cloudtrail:us-east-1:123456789012:trail/arn"
        }
      }
    }
  ]
}
```

The resource policy evidence shows a CloudTrail-focused bucket policy with three allow statements: ACL check, management-account log write, and organization log write. The policy uses the cloudtrail.amazonaws.com service principal, aws:SourceArn conditions, and bucket-owner-full-control ACL requirements.

Figure 3 - S3 Bucket Policy Successfully Edited



The S3 permissions evidence shows the successful bucket policy update banner, the centralized logging bucket name, Block all public access enabled, and the bucket policy section present on the Permissions tab.

Security Analysis

The bucket policy is necessary because CloudTrail must be allowed to write to a bucket located in the SecurityAudit account. This is resource-based access rather than a normal identity-based IAM user workflow.

The policy limits the principal to the CloudTrail service and scopes access to the intended bucket and AWSLogs paths rather than granting broad S3 access.

The aws:SourceArn condition helps prevent the confused deputy problem by ensuring that only the intended trail can use the CloudTrail service principal to write into this bucket.

The bucket-owner-full-control ACL requirement helps ensure that the logging bucket owner retains control over delivered log objects.

Keeping Block Public Access enabled is important because centralized security logs should not be exposed to the public Internet.

Lessons Learned

S3 bucket policies are resource-based policies. They control access at the bucket resource rather than attaching permissions directly to an IAM identity.

S3 buckets and objects are private by default, but misconfigured bucket policies can create serious exposure. Block Public Access should remain enabled for security log storage.

Condition keys are important in service-to-service access because they narrow who can use an AWS service principal to interact with a resource.

Centralized logging requires multiple layers: cross-account access, a dedicated logging bucket, a restrictive bucket policy, and a CloudTrail configuration that sends logs to the bucket.

Production Improvements

- Enable S3 versioning and Object Lock where retention requirements justify it.
- Use server-side encryption with clear key ownership and rotation requirements.
- Add lifecycle rules for retention and cost control once log retention requirements are defined.
- Monitor bucket policy changes, public-access changes, and unexpected PutObject activity.
- Validate CloudTrail delivery into the bucket after the organization trail is configured.
- Use centralized alerting for CloudTrail delivery failures and unauthorized bucket policy modifications.

Skills Demonstrated

S3 bucket policies	Confused-deputy mitigation	AWS CloudTrail
Policy conditions	Block Public Access	Amazon S3
Service principals	Centralized logging design	Cross-account administration

Resume Bullet

RESUME

Secured a centralized AWS CloudTrail logging bucket by applying a resource-based S3 bucket policy that restricts CloudTrail service access with SourceArn conditions, bucket-owner-full-control requirements, and S3 Block Public Access protections.

STAR Interview Story

Situation: The SecurityAudit account contained the S3 bucket that would store centralized CloudTrail logs for the organization.

Task: Allow CloudTrail to deliver logs to the bucket without making the bucket public or granting broad S3 permissions.

Action: I assumed into SecurityAudit, customized a CloudTrail bucket policy with the bucket ARN, trail ARN, management account ID, and organization ID, then saved the policy while keeping Block Public Access enabled.

Result: The logging bucket now has a restricted resource-based policy that prepares it for centralized CloudTrail delivery and reduces confused-deputy and public exposure risks.

Version History

v1.0.0	July 10, 2026	Initial documented implementation. Assumed the SecurityAudit account, applied a resource-based S3 bucket policy for CloudTrail log delivery, preserved Block Public Access, documented CloudTrail service permissions and conditions, and embedded all provided project evidence using portfolio documentation standard v1.0.1.

References

- Cloud Security Lab a Week (S.L.A.W.) - Secure that Bucket! (Centralized Logging: Part 2), Resource Policies.
- User-provided CloudTrail bucket policy JSON evidence.
- User-provided S3 bucket permissions and successful policy update evidence.
- Project 10 - Cross-Account Role and Centralized Logging S3.